SOMAIYA VIDYAVIHAR UNIVERSITY
K J Somaiya School of Engineering

Somaiya TRUST

# OpenVAS

## Open Vulnerability Assessment System

*Comprehensive Network Security Scanning & Vulnerability Management*


Shail Shaji – 16010123306
Shayaan Amir – 16010123313
Shounak Shelke - 16010123318

# What is OpenVAS?

OpenVAS (Open Vulnerability Assessment System) is a full-featured, open-source vulnerability scanner and management solution maintained by Greenbone Networks as part of the GVM suite.

## Open Source

Free under GNU GPL license with community-driven updates and transparency

## Comprehensive

Supports both authenticated and unauthenticated scans across networks and systems

## Actively Maintained

Continuously updated NVT feed with 90,000+ vulnerability tests available

# History & Evolution

| 2005 | 2006 | 2008 | 2017 | 2019+ |
|---|---|---|---|---|
| **Nessus Goes Proprietary** | **OpenVAS Born** | **Greenbone Takes Over** | **GVM Framework** | **GVM 11 & Beyond** |
| Tenable makes Nessus closed-source, triggering a community fork | Community forks Nessus 2.x to create OpenVAS as an open alternative | Greenbone Networks becomes the primary sponsor and maintainer | Rebranded to Greenbone Vulnerability Management (GVM) suite | Modular architecture with OpenVAS Scanner, gvmd, GSA, and OSPd |

# Key Features & Capabilities

## Authenticated Scanning

Login-based scanning detects vulnerabilities requiring system access, providing deeper insight than unauthenticated scans.

## NVT Feed (90,000+)

Access to 90,000+ Network Vulnerability Tests updated daily by Greenbone and the open-source community.

## Flexible Scheduling

Automate scans at defined intervals — hourly, daily, or weekly — for continuous monitoring.

## Multi-format Reporting

Export results as PDF, XML, HTML, or CSV for compliance documentation and stakeholder reporting.

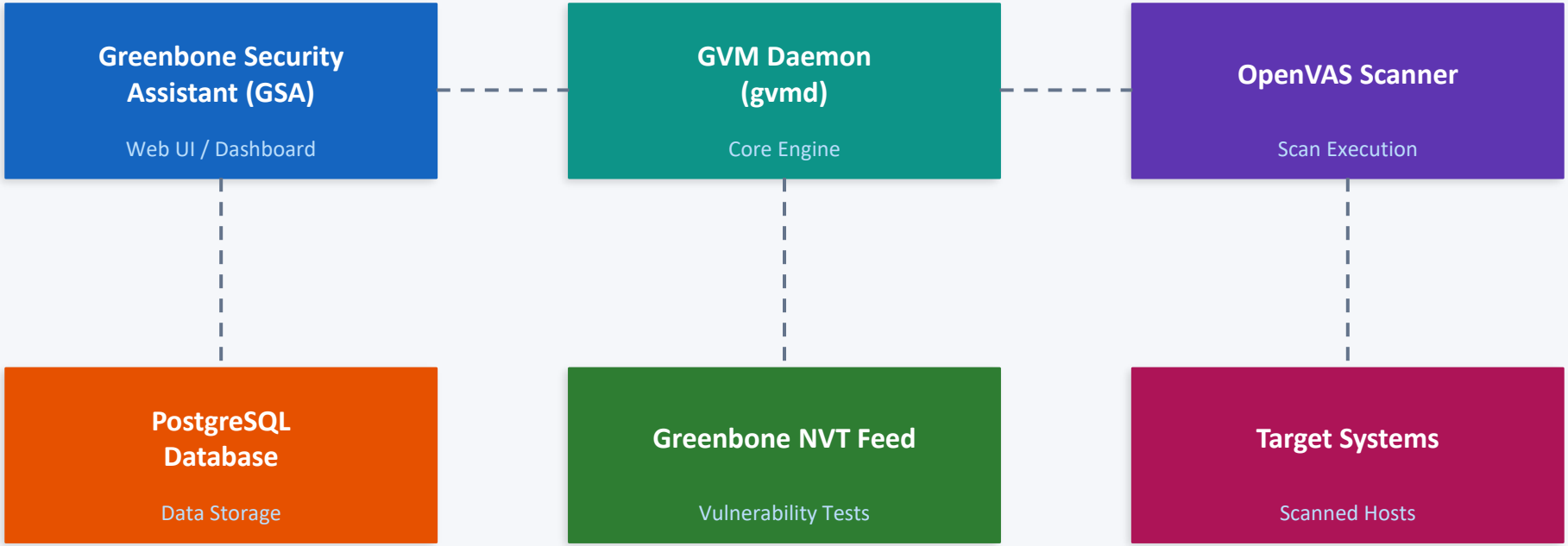
## Web Interface (GSA)

Greenbone Security Assistant provides a browser-based dashboard for intuitive scan and report management.

## Policy & Compliance

Built-in scan configs support compliance standards including PCI-DSS, HIPAA, and CIS Benchmarks.

# OpenVAS Architecture



# How OpenVAS Works — Scanning Workflow

### 01 Define Target

Specify IP addresses, hostnames, or CIDR ranges to scan

### 02 Configure Scan

Choose policy: Full & Fast, Discovery, or custom NVT selection

### 03 Launch Scan

gvmd orchestrates; OpenVAS Scanner executes NVTs against targets

### 04 NVT Execution

Each NVT probes specific services, ports, and software versions

### 05 Result Analysis

Findings are categorized by CVSS severity: Critical, High, Medium, Low

### 06 Report Generation

Export detailed report with CVE references, risk ratings, and fixes

# Network Vulnerability Tests (NVTs)

## What are NVTs?

- Scripts written in NASL (Nessus Attack Scripting Language)
- Each NVT tests for a specific vulnerability or misconfiguration
- Updated daily via Greenbone Community or Enterprise Feed
- Organized by family: Web Apps, Linux, Windows, Databases, etc.
- Each NVT references CVE IDs, CVSS scores, and fix steps
- Over 50,000 NVTs available in the community feed alone

**50,000+**

Total NVTs

**Daily**

Feed Updates

**NASL**

Script Language

**CVE**

Reference Format

# Configuring & Running Your First Scan



1. **Log in to GSA** Access the Greenbone Security Assistant at https://localhost:9392 with your admin credentials.
2. **Create a Target** Go to Configuration > Targets > New Target. Enter a name, IP/hostname, and select a port list.
3. **Select Scan Config** Choose "Full and Fast" for comprehensive scans or "Discovery" for host enumeration only.
4. **Create a Task** Go to Scans > Tasks > New Task. Assign your target and scan config, then optionally set a schedule.
5. **Launch the Scan** Click the Start button on your task. Monitor progress in real-time via the status bar.
6. **View the Report** Once complete, open the task report. Filter results by severity and export as PDF or XML.

# Understanding Scan Results & Reports

## CVSS Severity Ratings

| | |
|---|---|
| **Critical** | **9.0 – 10.0**<br>Immediate action required — remotely exploitable, no auth needed |
| **High** | **7.0 – 8.9**<br>Serious risk — exploitable with low complexity or few privileges |
| **Medium** | **4.0 – 6.9**<br>Moderate risk — requires some user interaction or local access |
| **Low** | **0.1 – 3.9**<br>Minor risk — limited impact or complex exploitation required |
| **Log/Info** | **0.0**<br>Informational only — no direct security risk identified |

## Report Contains

- Vulnerability name & CVE identifier
- Affected host, port & service details
- CVSS score & vector string
- Detailed description of the flaw
- Solution / remediation steps
- External references (NVD, vendor advisories)
- Export formats: PDF, XML, HTML, CSV

# Real-World Use Cases & Applications

### Network Auditing

Periodically scan enterprise networks to identify unpatched systems, open ports, and misconfigurations before attackers do.

### Penetration Testing

Used as a reconnaissance and vulnerability identification tool in red team and pen testing engagements.

### Compliance & Auditing

Support regulatory compliance for PCI-DSS, HIPAA, and ISO 27001 by identifying non-compliant systems.

### Healthcare Security

Scan medical device networks for vulnerabilities in connected IoT equipment and hospital IT infrastructure.

### Education & Training

Widely used in cybersecurity labs and courses to teach vulnerability assessment hands-on.

### DevSecOps Pipelines

Integrated into CI/CD pipelines to scan infrastructure before deployment, catching misconfigs early.

# OpenVAS vs Other Vulnerability Scanners

| Feature | OpenVAS | Nessus | Qualys |
|---|---|---|---|
| **Cost** | Free (Open Source) | Paid ($3,000+/yr) | Paid (SaaS) |
| **License** | GPL — Open Source | Proprietary | Proprietary SaaS |
| **NVT/Plugin Count** | 90,000+ (Community) | 59,000+ (Professional) | 80,000+ |
| **Cloud Scanning** | No (Self-hosted) | No (Self-hosted) | Yes (Cloud-native) |
| **Ease of Setup** | Moderate | Easy | Easy |
| **Compliance** | PCI, HIPAA (basic) | Extensive | Extensive |
| **Reporting** | PDF, XML, HTML, CSV | PDF, HTML, CSV | PDF, HTML, CSV |
| **API Support** | Yes (GMP API) | Yes (REST API) | Yes (REST API) |

# Limitations & Challenges



## False Positives

OpenVAS may flag legitimate services as vulnerable. Each finding should be manually verified before remediation.

## Performance on Large Networks

Scanning large IP ranges is slow and resource-intensive without proper hardware tuning and allocation.

## Complex Initial Setup

Feed sync, TLS certificates, and database setup have a steep learning curve for beginners.

## Limited Cloud Scanning

No native support for scanning cloud infrastructure (AWS, Azure, GCP) compared to commercial alternatives.

## Community Feed Lag

The free community feed may lag behind the commercial Greenbone Enterprise Feed in coverage and update speed.

## No Built-in Asset Management

Unlike commercial tools, OpenVAS lacks mature asset inventory and remediation tracking out of the box.

# Conclusion



- OpenVAS is a powerful, free, and open-source vulnerability scanner suitable for professionals and organizations alike
- Its continuously updated NVT feed and flexible scan configurations make it a strong alternative to commercial tools
- Ideal for network auditing, compliance checking, and security training — though commercial tools may have the edge at enterprise scale
- Understanding its limitations — false positives, setup complexity, and cloud support gaps — is key to using it effectively

## References


- Greenbone Networks — Official Documentation: https://docs.greenbone.net
- OpenVAS Project: https://www.openvas.org
- National Vulnerability Database (NVD): https://nvd.nist.gov
- CVSS Scoring Standard: https://www.first.org/cvss